

Módulo 7: DevSecOps y Cierre

T21: OWASP Top 10 — Repaso Final

Carlos Rodríguez Contreras · GitHub: karrocon

 *Mapa completo del OWASP Top 10 — qué has explotado, qué falta explorar*

Objetivos

- Mapear todo lo trabajado en el curso al OWASP Top 10 (2025)
- Identificar qué categorías no hemos cubierto y cómo seguir aprendiendo
- Revisar el informe de auditoría completo de VulnApp
- Siguiendo paso: recursos avanzados, certificaciones, laboratorios online

OWASP Top 10 (2025) – Mapa completo

#	Categoría	Cubierto en
A01	Broken Access Control	T08 (IDOR), T09 (CSRF)
A02	Security Misconfiguration	T13 (Headers), T16 (DB), T17 (Docker)
A03	Software Supply Chain Failures	T14 (Dependencies), T19 (CI/CD)
A04	Cryptographic Failures	T10 (TLS), T11 (Passwords), T12 (Secrets)
A05	Injection	T04 (SQLi), T05 (XSS), T06 (CMDi)
A06	Insecure Design	T15 (SSRF), T08 (IDOR)
A07	Authentication Failures	T07 (JWT), T09 (Sessions)
A08	Software/Data Integrity Failures	T19 (CI/CD pipelines)
A09	Security Logging & Alerting Failures	T19, T20 (ZAP)
A10	Mishandling of Exceptional Conditions	T06 (error info leak)

Lo que has explotado en este curso

Ataques realizados:

-  SQL Injection (bypass login)
-  XSS Almacenado (robo de cookie)
-  Command Injection (ejecución remota)
-  JWT falsificado (alg:none)
-  IDOR (acceso a datos ajenos)
-  Fuerza bruta JWT (clave débil)
-  Lectura de secretos (env expuesto)

Defensas implementadas:

-  Prepared statements
-  Sanitización HTML (XSS)
-  Allowlist de comandos
-  JWT con algorithms + clave fuerte
-  Verificación de pertenencia (IDOR)
-  bcrypt para contraseñas
-  helmet.js (headers)
-  Docker seguro (no-root)
-  nginx + HTTPS

Recursos para seguir aprendiendo

Recurso	Tipo	URL
PortSwigger Web Security Academy	Labs gratuitos	portswigger.net/web-security
OWASP WebGoat	App vulnerable guiada	owasp.org/www-project-webgoat
HackTheBox	CTF + labs	hackthebox.com
TryHackMe	Rutas guiadas	tryhackme.com
PentesterLab	Ejercicios progresivos	pentesterlab.com

OWASP Cheat Sheets — referencia rápida

Cheat Sheet	Tema	Cuándo usarlo
Authentication	Login, MFA, credential storage	Diseñar flujo de auth
Session Management	Cookies, tokens, timeout	Implementar sesiones
Input Validation	Sanitización, allowlists	Procesar input de usuario
SQL Injection Prevention	Prepared statements, ORM	Cualquier query a BD
XSS Prevention	Encoding, CSP	Renderizar datos de usuario
REST Security	Auth, rate limit, CORS	Diseñar APIs
Docker Security	Dockerfile, compose	Containerizar apps

 **URL:** cheatsheetseries.owasp.org — referencia gratuita mantenida por la comunidad OWASP.

Carreras en ciberseguridad

Rol	Día a día	Skills clave
AppSec Engineer	Revisar código, threat modeling, secure SDLC	Programación + OWASP
Pentester	Buscar vulns, escribir exploits, informes	Hacking + comunicación
Security Engineer	Infraestructura segura, SIEM, respuesta	Cloud + automation
Bug Bounty Hunter	Freelance, encontrar bugs en plataformas	Web hacking + persistence
GRC Analyst	Compliance, auditorías, políticas	Normativa + procesos

✓ Con lo aprendido en este curso tienes una base sólida para cualquiera de estos caminos.

Certificaciones recomendadas

Certificación	Nivel	Enfoque
CompTIA Security+	Entrada	Seguridad general
eJPT (eLearnSecurity)	Entrada	Pentesting práctico
CEH (EC-Council)	Intermedio	Hacking ético
OSCP (OffSec)	Avanzado	Pentesting (examen práctico 24h)
BSCP (PortSwigger)	Intermedio	Web security

Resumen del curso



De observar → atacar → proteger → desplegar → auditar.

Ahora sabes cómo piensan los atacantes y cómo defender tus aplicaciones.

🏆 ¡Enhorabuena! Has completado el curso de seguridad web.



Lab T21: Informe de auditoría final

Objetivo: completar y entregar el informe de auditoría de VulnApp

Usando la plantilla del curso:

1. Completa la tabla de hallazgos con todas las vulnerabilidades explotadas
2. Asigna severidad CVSS a cada hallazgo
3. Para cada hallazgo incluye: descripción, evidencia (captura), fix aplicado
4. Añade una sección de "Recomendaciones generales" con los top 5 puntos de mejora

✓ **¡Enhorabuena!** Has completado el curso. Ahora conoces el OWASP Top 10 desde dentro.